Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization

Overview :-

Integrate of Zscaler with Identity Providers (IdPs) like Microsoft Azure Active Directory, Okta, and Active Directory helps provide secure and seamless authentication for users. When a user tries to access the internet or applications through Zscaler, the system redirects the login request to the Identity and sends authentication confirmation back to Zscaler.

Zscaler is a cloud-based security platform that protects users while accessing the internet and enterprise applications. This integration enables Single Sign - On (SSO), improves security, and allows centralized user identity management. It also supports secure protocols like SAML, OAuth, OpenID Connect for authentication and authorization.

Team Members :-

S.NO	COLLEGE	NAME	EMAIL ID
01	MAHARANI ARTS & SCIENCE WOMENS COLLEGE	VALARMATHI.B	78068bala@gmail.com
02	MAHARANI ARTS & SCIENCE WOMENS COLLEGE	NEELAVENI.U	neelavenin487@gmail.com
03	MAHARANI ARTS & SCIENCE WOMENS COLLEGE	MALLESHWARI.M	kaviyaras876@gmail.com
04	MAHARANI ARTS & SCIENCE WOMENS COLLEGE	KARNIGADEVI.G	karnikutty3711@gmail.com

05	MAHARANI ARTS & SCIENCE WOMENS COLLEGE	KAVITHA .M	kavithams9713@gmail.com

STAGE-1

VULNERABILITY TABLE

S.NO	VULNERABILITY NAME	PLUGIN ID	SEVERITY
1	SSL Version 2 and 3 Protocol Detection	20007	critical
2	SSL Medium Strength Cipher Suites Supported (SWEET32)	42873	high
3	SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eNcryption)	89058	medium
4	SSL/TLS EXPORT_RSA <= 512-bit Cipher Suites Supported (FREAK)	81606	medium
5	SSL Certificate Signed Using Weak Hashing Algorithm (Known CA)	95631	info
6	SSL/TLS Recommended Cipher Suites	156899	info
7	Nessus SYN scanner	11219	info
8	Service Detection	22964	info

9	**Additional DNS Hostnames**	**46180**	**info**
10	**Common Platform Enumeration (CPE)**	**45590**	**info**

REPORT:

DETAILED VULNERABILITY ANALYSIS:

1. SSL Version 2 and 3 Protocol Detection

CWE / CVE

- **CWE-327 – Use of Broken Cryptographic Algorithm**
- **CVE-2014-3566**

OWASP Category

A02:2021 – Cryptographic Failures

Description

The server supports outdated encryption protocols SSLv2 and SSLv3. These protocols contain cryptographic weaknesses such as insecure padding and weak encryption methods. Attackers can exploit these weaknesses to perform man-in-the-middle attacks or decrypt sensitive communication between client and server.

Business Impact

Sensitive information such as login credentials, personal data, and financial details can be intercepted. This may lead to data breaches, financial loss, and loss of customer trust.

Output

```
  Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)

    Name                          Code             KEX           Auth     Encryption             MAC
    ----------------------        ----------       ---           ----     ---------------------  ---
    DES-CBC3-MD5                  0x07, 0x00, 0xC0 RSA           RSA      3DES-CBC(168)          MD5
    EDH-RSA-DES-CBC3-SHA          0x00, 0x16       DHE           RSA      3DES-CBC(168)          SHA1
    DES-CBC3-SHA                  0x00, 0x0A       RSA           RSA      3DES-CBC(168)          SHA1

The fields above are :

  {Tenable ciphername}
  {Cipher ID code}
  Kex={key exchange}
  Auth={authentication}
  Encrypt={symmetric encryption method}
  MAC={message authentication code}
  {export flag}
```

2.SSL Medium Strength Cipher Suites Supported (SWEET32)

CWE / CVE

- **CWE-326 – Inadequate Encryption Strength**
- **CVE-2016-2183**

OWASP Category

A02:2021 – Cryptographic Failures

Description

The remote server supports medium-strength SSL cipher suites, including the 3DES encryption algorithm.
Medium strength encryption uses key lengths between 64-bit and 112-bit. These encryption methods are considered outdated and less secure compared to modern standards.
Attackers on the same network can exploit this weakness to perform SWEET32 attacks, allowing them to recover portions of encrypted data.

Business Impact

If exploited, attackers may decrypt sensitive information such as login credentials, session cookies, or confidential data transmitted between users and the server. This may result in data leakage, security breaches, and loss of customer trust.

Output

```
  Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)

    Name                          Code             KEX           Auth     Encryption             MAC
    ----------------------        ----------       ---           ----     ---------------------  ---
    DES-CBC3-MD5                  0x07, 0x00, 0xC0 RSA           RSA      3DES-CBC(168)          MD5
    EDH-RSA-DES-CBC3-SHA          0x00, 0x16       DHE           RSA      3DES-CBC(168)          SHA1
    DES-CBC3-SHA                  0x00, 0x0A       RSA           RSA      3DES-CBC(168)          SHA1

The fields above are :

  {Tenable ciphername}
  {Cipher ID code}
  Kex={key exchange}
  Auth={authentication}
  Encrypt={symmetric encryption method}
  MAC={message authentication code}
  {export flag}
```

3. SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eNcryption)

CWE / CVE

- **CWE-310 – Cryptographic Issues**
- **CVE-2016-0800**

OWASP Category

A02:2021 – Cryptographic Failures

Description

The remote server supports SSLv2 protocol, which is outdated and insecure. Because of this, the server is vulnerable to the DROWN (Decrypting RSA with Obsolete and Weakened eNcryption) attack.
In this attack, an attacker can use weaknesses in SSLv2 to decrypt TLS encrypted traffic. A man-in-the-middle attacker can capture encrypted communication and later decrypt it using specially crafted requests to a server that still supports SSLv2 with the same private key.

Business Impact

If exploited, attackers may decrypt confidential data such as login credentials, session cookies, and sensitive user information. This may lead to data breaches, unauthorized access, financial loss, and damage to the organization's reputation.

Output

```
The remote host is affected by SSL DROWN and supports the following
vulnerable cipher suites :

  Low Strength Ciphers (<= 64-bit key)

    Name                          Code             KEX           Auth     Encryption             MAC
    ----------------------        ----------       ---           ----     ---------------------  ---
    EXP-RC2-CBC-MD5               0x04, 0x00, 0x80 RSA           RSA      RC2-CBC(40)            MD5       export
    EXP-RC4-MD5                   0x02, 0x00, 0x80 RSA           RSA      RC4(40)                MD5       export

  High Strength Ciphers (>= 112-bit key)

    Name                          Code             KEX           Auth     Encryption             MAC
    ----------------------        ----------       ---           ----     ---------------------  ---
    RC4-MD5                       0x01, 0x00, 0x80 RSA           RSA      RC4(128)               MD5

The fields above are :

  {Tenable ciphername}
  {Cipher ID code}
  Kex={key exchange}
  Auth={authentication}
  Encrypt={symmetric encryption method}
  MAC={message authentication code}
  {export flag}
```

4. SSL/TLS EXPORT_RSA <= 512-bit Cipher Suites Supported (FREAK)

CWE / CVE

- **CWE-326 – Inadequate Encryption Strength**
- **CVE-2015-0204**

OWASP Category

A02:2021 – Cryptographic Failures

Description

The remote server supports EXPORT_RSA cipher suites that use very weak RSA keys (512-bit or less).
These weak encryption keys can be broken easily by attackers. A man-in-the-middle attacker can force the connection to downgrade to these weak cipher suites and then factor the RSA key to decrypt the secure communication.

Business Impact

Attackers may intercept and decrypt sensitive data such as user credentials, financial information, and private communications. This can result in data breaches, unauthorized access, and loss of organizational reputation.

Output

```
EXPORT_RSA cipher suites supported by the remote server :

  Low Strength Ciphers (<= 64-bit key)

    Name                        Code            KEX         Auth    Encryption          MAC
    ----------------------      ----------      ---         ----    --------------------  ---
    EXP-DES-CBC-SHA             0x00, 0x08      RSA         RSA     DES-CBC(40)         SHA1     export
    EXP-RC2-CBC-MD5             0x00, 0x06      RSA         RSA     RC2-CBC(40)         MD5      export
    EXP-RC4-MD5                 0x00, 0x03      RSA         RSA     RC4(40)             MD5      export

The fields above are :

  {Tenable ciphername}
  {Cipher ID code}
  Kex={key exchange}
  Auth={authentication}
  Encrypt={symmetric encryption method}
  MAC={message authentication code}
  {export flag}
```

5. SSL Certificate Signed Using Weak Hashing Algorithm (Known CA)

CWE / CVE

- **CWE-327 – Use of a Broken or Risky Cryptographic Algorithm**
- **CVE-2004-2761**

OWASP Category

A02:2021 – Cryptographic Failures

Description

The SSL certificate chain used by the remote host is signed using a weak hashing algorithm such as SHA-1, MD5, or MD2. These algorithms are considered insecure because they are vulnerable to collision attacks, where attackers can generate two different inputs that produce the same hash value.
Because of this weakness, an attacker could create a forged certificate with the same digital signature and impersonate the legitimate server.

Business Impact

If exploited, attackers may masquerade as the legitimate website, intercept encrypted communications, and steal sensitive information such as user credentials, personal data, or financial details. This may lead to data breaches, phishing attacks, and loss of user trust.

Output

```
The following known CA certificates were part of the certificate
chain sent by the remote host, but contain hashes that are considered
to be weak.

Subject            : C=US/O=DigiCert Inc/OU=www.digicert.com/CN=DigiCert Global Root CA
Signature Algorithm : SHA-1 With RSA Encryption
Valid From         : Nov 10 00:00:00 2006 GMT
Valid To           : Nov 10 00:00:00 2031 GMT
Raw PEM certificate :
-----BEGIN CERTIFICATE-----
MIIDrzCCApegAwIBAgIQCDvgVpBCRrGhdWrJWZHHSjANBgkqhkiG9w0BAQUFADBhMQswCQYDVQQGEwJVUzEVMBMGA1UEChMMRGlnaUNlcnQgSW5jMRkw
FwYDVQQLExB3d3cuZGlnaWNlcnQuY29tMSAwHgYDVQQDExdEaWdpQ2VydCBHbG9iYWwgUm9vdCBDQTAeFw0wNjExMTAwMDAwMDBaFw0zMTExMTAwMDAw
MDBaMGExCzAJBgNVBAYTAlVTMRUwEwYDVQQKEwxEaWdpQ2VydCBJbmMxGTAXBgNVBAsTEHd3dy5kaWdpY2VydC5jb20xIDAeBgNVBAMTF0RpZ2lDZXJ0
IEdsb2JhbCBSb290IENBMIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEA4jvhEXLeqKTTo1eqUKKPC3eQyaKl7hLOllsBCSDMAZOnTjC3U/dD
xGkAV53ijSLdhwZAAIEJzs4bg7/fzTtxRuLWZscFs3YnFo97nh6Vfe63SKMI2tavegw5BmV/Sl0fvBf4q77uKNd0f3p4mVmFaG5cIzJLv07A6Fpt43C/
dxC//AH2hdmoRBBYMql1GNXRor5H4idq9Joz+EkIYIvUX7Q6hL+hqkpMfT7PT19sdl6gSzeRntwi5m3OFBqOasv+zbMUZBfHWymeMr/y7vrTC0LUq7dB
MtoM1O/4gdW7jVg/tRvoSSiicNoxBN33shbyTApOB6jtSj1etX+jkMOvJwIDAQABo2MwYTAOBgNVHQ8BAf8EBAMCAYYwDwYDVR0TAQH/BAUwAwEB/zAd
BgNVHQ4EFgQUA95QNVbRTLtm8KPiGxvDl7I90VUwHwYDVR0jBBgwFoAUA95QNVbRTLtm8KPiGxvDl7I90VUwDQYJKoZIhvcNAQEFBQADggEBAMucN6pI
ExIK+t1EnE9SsPTfrgT1eXkIoyQY/EsrhMAtudXH/vTBH1jLuG2cenTnmCmrEbXjcKChzUyImZOMkXDiqw8cvpOp/2PV5Adg06O/nVsJ8dWO41P0jmP6
P6fbtGbfYmbW0W5BjfIttep3Sp+dWOIrWcBAI+0tKIJFPnlUkiaY4IBIqDfv8NZ5YBberOgOzW6sRBc4L0na4UU+Krk2U886UAb3LujEV0lsYSEY1QSt
eDwsOoBrp+uvFRTp2InBuThs4pFsiv9kuXclVzDAGySj4dzp30d8tbQkCAUw7C29C79Fv1C5qfPrmAESrciIxpg0X40KPMbp1ZWVbd4=
-----END CERTIFICATE-----
```

6. SSL/TLS Recommended Cipher Suites

CWE / CVE

- **CWE-326 – Inadequate Encryption Strength**
- **Related vulnerability example: CVE-2013-2566**

OWASP Category

A02:2021 – Cryptographic Failures

Description

The remote host supports several weak or discouraged SSL/TLS cipher suites such as RC4, DES, 3DES, and export-grade ciphers.
These cipher suites provide low or medium strength encryption and are considered outdated. Attackers can exploit these weak encryption algorithms to break encrypted communication or downgrade the connection to insecure cipher suites.

Modern security standards recommend using TLS 1.2 or TLS 1.3 with strong cipher suites such as AES-GCM or CHACHA20-POLY1305.

Business Impact

If weak cipher suites are enabled, attackers may intercept or decrypt sensitive communications, including login credentials, personal data, or financial information. This may lead to data breaches, unauthorized access, compliance violations, and damage to the organization's reputation.

Output

```
The remote host has listening SSL/TLS ports which advertise the discouraged cipher suites outlined below:

  Low Strength Ciphers (<= 64-bit key)

    Name                          Code             KEX           Auth     Encryption             MAC
    ----------------------        ----------       ---           ----     ---------------------  ---
    EXP-RC2-CBC-MD5               0x04, 0x00, 0x80 RSA           RSA      RC2-CBC(40)            MD5       export
    EXP-RC4-MD5                   0x02, 0x00, 0x80 RSA           RSA      RC4(40)                MD5       export
    EXP-EDH-RSA-DES-CBC-SHA       0x00, 0x14       DHE           RSA      DES-CBC(40)            SHA1      export
    EDH-RSA-DES-CBC-SHA           0x00, 0x15       DHE           RSA      DES-CBC(56)            SHA1
    EXP-DES-CBC-SHA               0x00, 0x08       RSA           RSA      DES-CBC(40)            SHA1      export
    EXP-RC2-CBC-MD5               0x00, 0x06       RSA           RSA      RC2-CBC(40)            MD5       export
    EXP-RC4-MD5                   0x00, 0x03       RSA           RSA      RC4(40)                MD5       export
    DES-CBC-SHA                   0x00, 0x09       RSA           RSA      DES-CBC(56)            SHA1

  Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)

    Name                          Code             KEX           Auth     Encryption             MAC
    ----------------------        ----------       ---           ----     ---------------------  ---
    DES-CBC3-MD5                  0x07, 0x00, 0xC0 RSA           RSA      3DES-CBC(168)          MD5
    EDH-RSA-DES-CBC3-SHA          0x00, 0x16       DHE           RSA      3DES-CBC(168)          SHA1
    DES-CBC3-SHA                  0x00, 0x0A       RSA           RSA      3DES-CBC(168)          SHA1

  High Strength Ciphers (>= 112-bit key)

    Name                          Code             KEX           Auth     Encryption             MAC
    ----------------------        ----------       ---           ----     ---------------------  ---
    RC4-MD5                       0x01, 0x00, 0x80 RSA           RSA      RC4(128)               MD5
    DHE-RSA-AES128-SHA            0x00, 0x33       DHE           RSA      AES-CBC(128)           SHA1
    DHE-RSA-AES256-SHA            0x00, 0x39       DHE           RSA      AES-CBC(256)           SHA1
    AES128-SHA                    0x00, 0x2F       RSA           RSA      AES-CBC(128)           SHA1
    AES256-SHA                    0x00, 0x35       RSA           RSA      AES-CBC(256)           SHA1

  Unrecognized Ciphers

    Name                          Code             KEX           Auth     Encryption             MAC
    ----------------------        ----------       ---           ----     ---------------------  ---
    TLS1_CK_RSA_WITH_RC4_128_MD5
    TLS1_CK_RSA_WITH_RC4_128_SHA
```

7. Nessus SYN scanner

CWE / CVE

- **Not Applicable (இது vulnerability இல்லை)**
- **CVE: Not Applicable**

OWASP Category

A05:2021 – Security Misconfiguration *(sometimes related when unnecessary ports are open)*

Description

The scan used a SYN (half-open) port scanning technique to identify open ports on the remote host.
This method sends a SYN packet to the server and checks the response to determine whether the port is open without completing the full TCP connection.

The scan discovered the following open ports on the host:

- **80 / TCP (HTTP)**
- **443 / TCP (HTTPS)**
- **8080 / TCP (HTTP Alternate)**

Open ports indicate that services are running and accessible over the network.

Business Impact

If unnecessary ports remain open, attackers may attempt to scan, exploit vulnerabilities in services, or gain unauthorized access. Open ports can increase the attack surface of the system.

Output

```
Port 80/tcp was found to be open
```

To see debug logs, please visit individual host

Port	Hosts
80 / tcp / www	54.82.22.214

```
Port 443/tcp was found to be open
```

To see debug logs, please visit individual host

Port	Hosts
443 / tcp	54.82.22.214

```
Port 8080/tcp was found to be open
```

To see debug logs, please visit individual host

Port	Hosts
8080 / tcp / www	54.82.22.214

8. Service Detection

CWE / CVE

- **Not Applicable**
- **CVE: Not Applicable**

OWASP Category

A05:2021 – Security Misconfiguration ***(service information disclosure related)***

Description

Nessus was able to identify the remote services running on the target host by analyzing the service banner or error messages returned by the server.
Service detection helps determine which applications or protocols are running on specific ports.

The scan identified the following services:

- **Port 80 / TCP – Web Server (HTTP)**
- **Port 8080 / TCP – Web Server (HTTP Alternate)**
- **Port 443 / TCP – TLS/HTTPS Server**

This means that web services are actively running and accessible on these ports.

Business Impact

If attackers identify the running services, they may attempt to exploit vulnerabilities in those services or gather information about the system configuration. This could increase the attack surface of the server.

Output

```
A web server is running on this port.
```

To see debug logs, please visit individual host

Port	Hosts
80 / tcp / www	54.82.22.214
8080 / tcp / www	54.82.22.214

```
A TLSv1 server answered on this port.
```

To see debug logs, please visit individual host

Port	Hosts
443 / tcp	54.82.22.214

9. Additional DNS Hostnames

CWE / CVE

- **Not Applicable**
- **CVE: Not Applicable**

OWASP Category

A05:2021 – Security Misconfiguration *(information exposure related)*

Description

During the scan, Nessus discovered additional DNS hostnames that point to the same remote host.
These hostnames are usually used for virtual hosting, where multiple websites are hosted on the same server using different domain names.

The scan identified the following hostname linked to the server:

- **zero.webappsecurity.com**

This means that the same server IP address 54.82.22.214 may host multiple websites using name-based virtual hosting.

Business Impact

If attackers discover additional hostnames, they may attempt to scan those domains for vulnerabilities. This can expose other applications or services running on the same server.

Output

```
The following hostnames point to the remote host :
  - zero.webappsecurity.com
```

To see debug logs, please visit individual host

Port	Hosts
N/A	54.82.22.214

10. Common Platform Enumeration (CPE)

CWE / CVE

- **Not Applicable**
- **CVE: Not Applicable**

OWASP Category

A05:2021 – Security Misconfiguration *(information disclosure related)*

Description

Nessus scan identified the operating system or software platform running on the remote host using the CPE (Common Platform Enumeration) standard.
CPE is a standardized naming method used to identify hardware, operating systems, and software products.

The scan result shows that the remote system matches the following CPE:

- **cpe:/o:microsoft:windows_vista → Microsoft Windows Vista**

This means the system is likely running Windows Vista or a related version.

Business Impact

If attackers identify the exact operating system, they can search for known vulnerabilities specific to that platform and attempt targeted attacks against the system.

Output

```
The remote operating system matched the following CPE :

  cpe:/o:microsoft:windows_vista -> Microsoft Windows Vista
```

STAGE-2

Overview:

Nessus is one of the world's most trusted vulnerability assessment solutions, developed by Tenable. It is an automated tool designed to identify security vulnerabilities, misconfigurations, and malware in a network or a web application. During our project, we utilized Nessus to perform a deep scan of our target environment to identify potential entry points that a hacker might exploit.

What I Understood About Nessus: Nessus works by using a vast library of "Plugins," which are small pieces of code used to check for specific security flaws. When we initiate a scan, Nessus sends packets to the target IP, analyzes the responses, and compares them against its database of known vulnerabilities (CVEs).

It categorizes findings into five severity levels:

- Critical: Immediate threat; must be patched urgently.
- High: Significant risk of exploitation.
- Medium: Potential risk that needs attention.

● Low: Minor issues or informational bugs.

● Informational: Details about the open ports and services without direct risks.

In the context of our Zscaler Private Access (ZPA) project, Nessus helped us identify which internal applications were vulnerable. This allowed us to prioritize which apps needed the strictest ZPA access policies to ensure a Zero Trust environment.

S.NO	VULNERABILITY NAME	PLUGIN ID	SEVERITY
1	Device Type	54615	info
2	Nessus Scan Information	19506	info
3	OS Fingerprints Detected	209654	info
4	OS Identification	11936	info
5	Remote Services Not Using Post-Quantum Ciphers	277650	info
6	Shor's Harvest Now Decrypt Later	298387	info
7	TCP/IP Timestamps Supported	25220	info
8	Traceroute Information	10287	info

1. **Device Type**

CWE / CVE

- **Not Applicable**
- **CVE: Not Applicable**

OWASP Category

A05:2021 – Security Misconfiguration *(information disclosure related)*

Description

During the scan, Nessus analyzed the remote operating system and network responses to determine the type of device connected to the network.

The scan result shows:

- **Remote Device Type: General-purpose device**
- **Confidence Level: 65%**

A general-purpose device usually refers to a standard computer system such as a desktop, laptop, or server rather than specialized devices like printers or routers.

Business Impact

If attackers identify the type of device on the network, they may try to perform targeted attacks based on the device type or operating system.

Solution

- **Limit information disclosure about systems.**
- **Use network security controls and firewalls.**
- **Regularly update and secure the system.**

Output

```
Remote device type : general-purpose
Confidence level : 65
```

To see debug logs, please visit individual host

Port	Hosts
N/A	54.82.22.214

2. Nessus Scan Information

CWE / CVE

- **Not Applicable**
- **CVE: Not Applicable**

OWASP Category

Not Applicable *(scan information only)*

Description

This plugin displays information about the vulnerability scan itself. It provides details about the scanning tool, configuration, and scan execution parameters.

The scan report includes information such as:

- **Nessus Version: 10.11.3**
- **Scanner Edition: Nessus Home**
- **Plugin Feed Version: 202602122158**
- **Scanner OS: Windows**
- **Scan Type: Normal Scan**
- **Scan Policy: Advanced Scan**
- **Scanner IP: 10.116.76.104**
- **Port Range: Default**
- **Scan Duration: 2052 seconds**

- **Scan Start Date: 14 March 2026**

It also shows warnings such as:

- **Plugins not updated (results may be outdated)**
- **No port scanner enabled (scan results may be incomplete)**

Business Impact

This information helps administrators analyze how the scan was performed and verify whether the scan configuration was correct. If plugins are outdated or scanning options are limited, vulnerabilities may be missed.

Solution

- **Update Nessus plugins regularly.**
- **Enable proper port scanning and vulnerability checks.**
- **Use updated scan policies for accurate results.**

Output

```
Information about this scan :

Nessus version : 10.11.3
Nessus build : 20047
Plugin feed version : 202602122158
Scanner edition used : Nessus Home

ERROR: Your plugins have not been updated since 2026/2/12
Performing a scan with an older plugin set will yield out-of-date results and
produce an incomplete audit. Please run nessus-update-plugins to get the
newest vulnerability checks from Nessus.org.

Scanner OS : WINDOWS
Scanner distribution : win-x86-64
Scan type : Normal
Scan name : valar
Scan policy used : Advanced Scan
Scanner IP : 10.116.76.104

WARNING : No port scanner was enabled during the scan. This may
lead to incomplete results.

Port range : default
Ping RTT : 1583.076 ms
Thorough tests : no
Experimental tests : no
Scan for Unpatched Vulnerabilities : no
Plugin debugging enabled : no
Paranoia level : 1
Report verbosity : 1
Safe checks : yes
Optimize the test : yes
Credentialed checks : no
Patch management checks : None
Display superseded patches : yes (supersedence plugin did not launch)
CGI scanning : disabled
Web application tests : disabled
Max hosts : 50
Max checks : 5
Recv timeout : 5
Backports : None
```

3. OS Fingerprints Detected

CWE / CVE

- **Not Applicable**

- **CVE: Not Applicable**

OWASP Category

A05:2021 – Security Misconfiguration *(information disclosure related)*

Description

Nessus used different network probing techniques such as TCP/IP, HTTP, SMB, SNMP, and SSL analysis to identify the possible operating systems running on the remote host. These techniques collect OS fingerprints, which are patterns in network responses that help estimate the operating system.

The scan detected possible operating systems:

- **Linux Kernel 2.x on CentOS (Confidence: 56%)**
- **Microsoft Windows Vista (Confidence: 65%)**

It also detected additional information from services such as:

- **HTTP Server: Apache-Coyote/1.1**
- **SSL Certificate related to zero.webappsecurity.com**

Because multiple fingerprints were found, the exact OS cannot be confirmed with full certainty.

Business Impact

If attackers identify the operating system and services, they may search for known vulnerabilities specific to that OS or software, which can help them perform targeted attacks.

Solution

- **Limit system information exposure.**
- **Use firewalls and intrusion detection systems.**
- **Regularly update the operating system and services.**

Output

```
Following OS Fingerprints were found

Remote operating system : Linux Kernel 2.x on CentOS release
Confidence level : 56
Method : MLSinFP
Type : unknown
Fingerprint : unknown

Remote operating system : Microsoft Windows Vista
Confidence level : 65
Method : SinFP
Type : general-purpose
Fingerprint : SinFP:
   P1:B10113:F0x12:W8192:O0204ffff:M1300:
   P2:B10113:F0x12:W8192:O0204ffff010303080402080affffffff44454144:M1300:
   P3:B00000:F0x00:W0:O0:M0
   P4:191603_7_p=8080R

Following fingerprints could not be used to determine OS :
 HTTP:!:Server: Apache-Coyote/1.1

SSLcert:!:i/CN:DigiCert TLS RSA SHA256 2020 CA1i/O:DigiCert Incs/CN:zero.webappsecurity.coms/O:Micro Focus LLC
38b71430838e0e8e7d9244a3461056401ec8ad0d
```

4. OS Identification

CWE / CVE

- **Not Applicable**
- **CVE: Not Applicable**

OWASP Category

A05:2021 – Security Misconfiguration *(information disclosure related)*

Description

Nessus uses different remote probing techniques such as TCP/IP, SMB, HTTP, and SNMP to identify the operating system running on the remote host.
By analyzing the network responses, Nessus attempts to guess the OS name and version.

In this scan, the detected operating system is:

- **Microsoft Windows Vista**
- **Confidence Level: 65%**
- **Detection Method: SinFP fingerprinting technique**

This means the system is likely running Windows Vista, but the result is based on probability and may not be 100% accurate.

Business Impact

If attackers identify the operating system and version, they can search for known vulnerabilities specific to that OS and attempt targeted attacks.

Solution

- **Limit system information exposure.**
- **Use firewalls and network security controls.**
- **Keep the operating system updated with the latest security patches.**

Output

```
Remote operating system : Microsoft Windows Vista
Confidence level : 65
Method : SinFP


The remote host is running Microsoft Windows Vista
```

5. Remote Services Not Using Post-Quantum Ciphers

CWE / CVE

- **CWE-326 – Inadequate Encryption Strength *(related cryptographic concern)***
- **CVE: Not Applicable**

OWASP Category

A02:2021 – Cryptographic Failures

Description

The scan detected that the TLS server on port 443 does not support post-quantum cryptographic cipher suites.
Traditional cryptographic algorithms such as RSA and Diffie-Hellman rely on mathematical problems like large prime factorization or discrete logarithms.

Future quantum computers could break these algorithms using Shor's algorithm, which means current encryption methods may become insecure in a post-quantum environment.

Business Impact

Currently this is not an immediate vulnerability, but in the future, powerful quantum computers could potentially break traditional encryption algorithms, exposing sensitive communications and confidential data.

Solution

- **Monitor developments in post-quantum cryptography.**
- **Implement quantum-resistant algorithms when available.**
- **Follow updated TLS security standards.**

6. Shor's Harvest Now Decrypt Later

CWE / CVE

- **CWE-326 – Inadequate Encryption Strength**
- **CVE: Not Applicable *(future cryptographic risk)***

OWASP Category

A02:2021 – Cryptographic Failures

Description

The scan detected that the TLS service uses cryptographic algorithms such as RSA and Diffie-Hellman for encryption and key exchange. These algorithms rely on mathematical problems like prime factorization and discrete logarithms.

In the future, powerful quantum computers could break these algorithms using Shor's algorithm, which was introduced by Peter Shor in 1994.

Because of this, attackers may capture encrypted communications now and decrypt them later when cryptographically relevant quantum computers (CRQC) become available.

Business Impact

If quantum computers become powerful enough, attackers could break current encryption methods, allowing them to decrypt sensitive communications such as financial data, authentication credentials, and confidential information.

Solution

- **Monitor developments in post-quantum cryptography.**
- **Replace vulnerable algorithms (RSA, DH, ECDH) with quantum-resistant cryptographic algorithms when available.**
- **Follow updated TLS security recommendations.**

7. TCP/IP Timestamps Supported

CWE / CVE

- **CWE-200 – Exposure of Sensitive Information to an Unauthorized Actor**
- **CVE: Not Applicable**

OWASP Category

A05:2021 – Security Misconfiguration

Description

The remote host implements TCP timestamps as defined in RFC 1323.

TCP timestamps are used to improve network performance and packet handling. However, a side effect of this feature is that an attacker may be able to calculate the system uptime of the remote host by analyzing the timestamp values.

This means attackers can determine how long the system has been running without reboot.

Business Impact

Attackers may use this information to gather system details for reconnaissance, which could help them plan further attacks.
Although it is a low severity issue, it can reveal useful information about the target system.

Solution

- **Disable TCP timestamps on the server if not required.**
- **Configure the operating system to hide uptime information.**

Example (Linux):

sysctl -w net.ipv4.tcp_timestamps=0

8. Traceroute Information

CWE / CVE

- **CWE: Not Applicable**
- **CVE: Not Applicable**

OWASP Category

Not Applicable (Informational)

Description

The scan performed a **traceroute** to identify the **network path** between the scanner and the target host.

Traceroute shows the **number of network hops (routers)** that packets travel through before reaching the destination server.

In this scan:

- Source IP: **10.116.76.104**
- Target IP: **54.82.22.214**
- **Hop Count: 3**

This means the data travels through **3 network devices** before reaching the target host.

Business Impact

This is **not a vulnerability**.
It only provides **network path information**, which can help in **network troubleshooting and analysis**.

Solution

No action required. This is **informational only**.

STAGE-3

1.SOC (Security Operations Center)

A Security Operations Center (SOC) is a centralized unit that deals with security issues on an organizational and technical level. It comprises a team of experts, processes, and technology designed to continuously monitor and improve an organization's security posture. In our study, we understood that a SOC is not just about tools; it is about the constant vigilance against cyber threats, ensuring that any suspicious activity is detected, analyzed, and responded to in real-time.

2.SOC - Cycle

The SOC cycle is a continuous process that ensures the effectiveness of security monitoring. It typically follows these phases:

● Preparation: Establishing the tools and team.

● Detection: Monitoring traffic to find anomalies.

● Analysis: Investigating the detected alerts to see if they are real threats.

● Response: Taking action to stop the threat (e.g., blocking an IP).

● Recovery & Lessons Learned: Restoring systems and improving the process based on the incident.

3.SIEM (Security Information and Event Management)

SIEM is the "brain" of the SOC. It is a technology that collects log data from various sources across the network (firewalls, servers, databases). We understood that SIEM provides two main functions: Information Management (storing logs) and Event Management (analyzing logs in real-time). It helps security analysts correlate different events to find a single complex attack.

4.SIEM Cycle

The SIEM cycle involves the flow of data to make it useful for analysts:

● Data Collection: Gathering logs from all devices.

● Data Normalization: Converting different log formats into a single standard format.

● Data Aggregation: Combining similar events to reduce noise.

● Correlation: Linking different events together using rules to identify an attack pattern.

● Alerting: Notifying the SOC team when a correlation rule is triggered.

5.MISP (Malware Information Sharing Platform)

MISP is an open-source threat intelligence platform. We understood that MISP allows organizations to share information about malware and cyber threats with each other. By using MISP, a SOC team can stay updated on the latest Indicators of Compromise (IoCs), such as malicious IP addresses or file hashes, which helps in proactive defense.

6.Your College Network Information

A typical college network is highly complex, consisting of thousands of users (students, faculty, and staff). It includes multiple Wi-Fi access points, computer labs, administrative servers, and library databases. Because of the open nature of a college network, it is highly susceptible to malware infections via student devices and phishing attacks.

7.How you think you deploy SOC in your college

To deploy a SOC in our college, I would follow a phased approach:

● Log Collection: Install agents on all department servers and core switches to send logs to a central SIEM.

● Tool Setup: Use an open-source or enterprise SIEM (like QRadar) to monitor the traffic.

● Student SOC Team: Form a team of trained students and faculty to monitor the dashboard during college hours.

● Incident Response: Create a policy where any detected threat leads to the automatic isolation of the affected lab or user account.

8.Threat Intelligence

Threat Intelligence is the knowledge of existing or emerging threats. It involves collecting data about attackers' motives and targets. In our project, we learned that integrating threat intelligence into a SIEM allows the SOC to know "who" is attacking and "how" they operate, rather than just seeing a random alert.

9.Incident Response

Incident Response (IR) is the organized approach to managing the aftermath of a security breach. The goal is to limit damage and reduce recovery time. We understood the "SANS" framework: Preparation, Identification, Containment, Eradication, Recovery, and Lessons Learned.

10.QRadar & Understanding about Tool

IBM QRadar is a powerful SIEM tool. We explored its dashboard, which provides a high-level view of "Offenses" (potential attacks). It uses "Magistrates" to prioritize alerts based on severity. We understood how QRadar analyzes network flows and log activity to provide a complete picture of the security environment.

Conclusion :-

Comprehensive Analysis of Security Operations

Stage 1: Insights from Web Application Testing

Through the initial phase of this project, I gained a profound understanding of the vulnerabilities that exist within the digital interface of an organization. Web application testing is not merely about finding bugs; it is about understanding the attacker's mindset. I learned how critical flaws like SQL Injection, Cross-Site Scripting (XSS), and Insecure Direct Object References (IDOR) can lead to catastrophic data breaches. The primary takeaway was that security must be integrated into the Software Development Life Cycle (SDLC) rather than being treated as an after thought.

Stage 2: Understanding the Nessus Vulnerability Report

The second stage shifted the focus from specific applications to broader network infrastructure. Analyzing a Nessus report taught me how to handle vast amounts of raw security data. I understood that a vulnerability scan is a diagnostic tool that identifies "open doors" such as outdated software, missing patches, and

weak configurations. More importantly, I learned the art of Risk Prioritization—understanding that a "Critical" vulnerability on a core server requires immediate action compared to a "Medium" vulnerability on an isolated workstation. This stage bridged the gap between identifying a problem and planning a technical solution.

Stage 3: Mastery of SOC, SIEM, and QRadar Dashboards
The final stage provided a "bird's-eye view" of enterprise security through the Security Operations Center (SOC) and SIEM tools like IBM QRadar. I understood that while Stages 1 and 2 are about finding holes, Stage 3 is about active monitoring and response. By exploring the QRadar dashboard, I learned how log correlation works—turning thousands of individual network events into a single "Offense" that an analyst can investigate. This stage taught me the importance of the SOC Cycle: from initial detection to the final lessons learned after an incident is closed.

Future Scope: The Next Frontier of Cybersecurity

1. AI and Machine Learning in Autonomous Defense
The future of Stage 3 (SOC/SIEM) is heavily transitioning toward Artificial Intelligence (AI) and Machine Learning (ML). Currently, security analysts have to manually write rules to detect threats. In the future, SIEM tools like QRadar will use "Self-Learning Algorithms" that understand the normal behavior of a network and automatically flag any tiny deviation without human intervention.

● Predictive Analytics: Instead of reacting to an attack that has already happened, AI will predict potential attack vectors based on global threat patterns.

● Automated Threat Hunting: AI bots will constantly "hunt" for hidden threats inside the network 24/7, reducing the "dwell time" (the time a hacker stays hidden in a system) from months to seconds.

2. Transition from SIEM to SOAR (The Automation Revolution)

While SIEM (Security Information and Event Management) is great for visibility, the future belongs to SOAR (Security Orchestration, Automation, and Response).

● Orchestration: This will allow different security tools (Firewalls, Email Security, Endpoint Protection) to "talk" to each other seamlessly.

● Playbook Automation: If a phishing email is detected, a SOAR playbook will automatically reset the user's password, scan their laptop, and block the malicious sender's IP across the entire company instantly. This removes the "human bottleneck" in incident response.

3. Zero Trust Architecture (ZTA)

The traditional idea of a "secure perimeter" (like a college firewall) is dying. The future scope involves moving toward a Zero Trust model.

● "Never Trust, Always Verify": In this future setup, even if you are inside the college Wi-Fi, the system will not trust your device automatically.

● Micro-segmentation: Each user and application will be isolated in its own tiny digital "bubble." Even if a hacker breaks into one student's laptop, they won't be able to move to the college's main server.

4. Quantum Cybersecurity and Post-Quantum Cryptography

As Quantum Computing becomes a reality, current encryption methods (like the ones used in Stage 1 Web Applications) will become easy to crack.

● Future Scope: Organizations will need to upgrade to Post-Quantum Cryptography (PQC). This involves developing new mathematical algorithms that even quantum computers cannot break.

● Stage 1 Impact: Web developers will have to rewrite how data is encrypted in

transit and at rest to stay safe from quantum-level attacks.

5. DevSecOps: Security at the Speed of Code

In Stage 1 (Web Application Testing), we currently test apps after they are built. The future scope is DevSecOps, where security testing happens at every single second of the coding process.

● IAST (Interactive Application Security Testing): This is a future technology that monitors an application's inner workings while it's running to find vulnerabilities that traditional scanners miss.

● Security as Code: Security policies will be written as code, making them easy to update and deploy across thousands of cloud servers simultaneously.

6. IoT and 5G Security Challenges

With the rise of IoT (Internet of Things) and 5G, billions of new devices (smart cameras, sensors, medical devices) will connect to networks like your college network.

● Future SOC Responsibility: SOC teams will no longer just monitor laptops and servers. They will have to monitor thousands of "smart" devices that often have very weak built-in security.

● Edge Computing Security: Processing data closer to the user (Edge) will require a decentralized SOC model, where security is handled at the "edge" of the network rather than just in a central data center.

Topics Explored

In this comprehensive project, I explored several core domains of cybersecurity that are essential for modern digital defense:

1. Vulnerability Management & Assessment: I studied the systematic process

of identifying, classifying, and prioritizing security weaknesses in an IT environment. This involved understanding how to differentiate between high-risk vulnerabilities that require immediate patching and low-risk flaws that can be monitored over time using the CVSS (Common Vulnerability Scoring System) framework.

2. Log Management and Normalization: I explored how massive amounts of raw data (logs) are collected from diverse sources like firewalls, routers, and servers. I understood the importance of "Normalization"—converting these different log formats into a single, readable standard so that a SIEM tool can analyze them effectively.
3. Event Correlation and Rule Logic: One of the most critical topics was learning how to connect the dots between seemingly unrelated network events. For example, I learned how a "failed login" followed by a "database access" from the same IP can trigger a correlation rule in a SIEM, identifying it as a potential brute-force attack.

4. Threat Intelligence Integration: I researched how external threat data (Global Threat Feeds) can be integrated into local security systems. This "Intelligence" allows a SOC team to be proactive—blocking malicious IPs and file hashes before they even interact with the organization's network.

5. Incident Response Lifecycle (IR): I studied the structured phases of responding to a security breach. Following the SANS/NIST framework, I explored the stages of Preparation, Identification, Containment, Eradication, Recovery, and Lessons Learned, ensuring a minimal impact on business continuity.

Tools Explored

Throughout the stages of this project, I gained hands-on familiarity with industry-standard security tools:

1. IBM QRadar (SIEM Platform): As a market-leading SIEM, I explored QRadar’s ability to provide a centralized view of security. I learned how to navigate its dashboard, analyze "Offenses," and understand "Network Flows." It served as the primary tool for real-time monitoring and event correlation during Stage 3.

2. Nessus (Vulnerability Scanner): I utilized Nessus to perform automated network security audits. I explored how to configure scan policies, run credentialed vs. non-credentialed scans, and generate detailed reports that highlight missing patches and configuration errors across a network.

3. Burp Suite (Web Vulnerability Scanner): During the Web Application Testing phase (Stage 1), I used Burp Suite to intercept and analyze HTTP/HTTPS traffic. This tool was instrumental in understanding how attackers exploit web-level flaws like SQL injection and broken authentication.

4. MISP (Malware Information Sharing Platform): I explored MISP as a tool for managing Threat Intelligence. I learned how to store, share, and correlate Indicators of Compromise (IoCs) like malicious URLs and malware signatures, which are then used to feed information into the SIEM for better detection.

—----------THE END—----------